© PNN 2025

# Lecture 4: Identification, Authentication, and Authorization

In today's digital landscape, securing access to systems and data is a critical aspect of cybersecurity. Identification, authentication, and authorization form the foundation of access control, ensuring that only legitimate users can interact with resources based on their permissions. Identification involves claiming an identity, authentication verifies the claimed identity, and authorization determines the level of access granted. Understanding these concepts and their associated mechanisms helps in designing secure and efficient access control systems that protect sensitive information from unauthorized access.

## 1. Identification

Identification is the process of asserting or claiming an identity to a system or service. It is the first step in access control, linking an individual to an account or system.

Users typically provide unique identifiers such as usernames, employee IDs, or email addresses to establish their identity. For example, when logging into an online account, entering a username serves as an identification mechanism.

## 2. Authentication

Authentication is the process of verifying the claimed identity to ensure that the user is who they claim to be.

### Types of Authentication Methods

There are different types of authentication methods, each offering varying levels of security.

**i) Knowledge-based Authentication**

Knowledge-based authentication relies on something the user knows, such as passwords, PINs, or security questions. However, this method is vulnerable to guessing or phishing attacks.

**ii) Possession-based Authentication**

Possession-based authentication involves something the user has, such as smart cards, security tokens, or mobile authenticator apps, making it more secure as it requires physical possession.

**iii) Biometric-based Authentication**

Biometric-based authentication relies on something the user is, such as fingerprint scans, facial recognition, or iris scans, offering strong security but still susceptible to spoofing.

**iv) Behavioral-based Authentication**

Behavioral-based authentication analyzes something the user does, such as typing patterns or gait analysis, and is emerging as a method for continuous authentication.

Examples of authentication include logging into an email account using a password or accessing a bank app with fingerprint authentication.

## 3. Authorization

Authorization determines and grants the appropriate level of access to resources based on a user's identity and roles.

**Authorization control Mechanisms**

Authorization is implemented through various access control mechanisms

**i) Access Control Lists (ACLs)**

Access Control Lists (AC)Ls) define access permissions for specific users or system processes by listing allowed or denied actions for each entity. ACLs operate at the file or resource level, ensuring that only authorized individuals can read, write, or execute specific data. They provide a straightforward approach to security but can become difficult to manage in complex environments where numerous users require different levels of access.

**ii) Role-Based Access Control (RBAC)**

Role-Based Access Control (RBAC) assigns permissions to users based on predefined roles rather than individual identities. This approach simplifies access management by categorizing users into roles with specific privileges. For example, an organization may grant managers access to financial reports while restricting regular employees from viewing such information. RBAC enhances security by ensuring that users only access what is necessary for their job functions while reducing administrative overhead.

**iii) Attribute-Based Access Control (ABAC).**

Attribute-Based Access Control (ABAC) extends access control by evaluating attributes such as user roles, device types, locations, and time of access. Unlike ACLs and RBAC, which rely on predefined lists or roles, ABAC dynamically assesses policies based on a combination of conditions before granting access. For example, an employee may access corporate systems from a company-issued laptop during work hours but be denied access from an untrusted device or external network. ABAC provides flexibility and fine-grained control, making it suitable for complex and dynamic environments.

For example, a manager may have access to HR files, while an employee can only view their own records. The primary purpose of authorization is to ensure that users can only perform actions and access data within their granted permissions. Practical applications include an employee using a

company's intranet with restricted sections based on their department or cloud services offering different access levels to administrators and regular users.

## 4. Best Practices

### i) Multi-Factor Authentication (MFA)

To enhance security, organizations implement best practices such as Multi-Factor Authentication (MFA), which combines two or more authentication factors. For instance, logging into an account with a password (something you know) and a code sent to a phone (something you have) significantly reduces the risk of unauthorized access.

### ii) Periodic Review of Access Rights

Another crucial practice is the periodic review of access rights, which involves regularly auditing user permissions to ensure they align with current roles and responsibilities. For example, access should be revoked for employees who change departments or leave the organization to minimize the risk of privilege creep and insider threats.

### iii) Enforcing Strong Password Policies

Additionally, enforcing strong password policies, such as requiring a minimum of 12 characters with a mix of upper-case, lower-case, numbers, and symbols, strengthens security.

### iv) Principle of Least Privilege (PoLP)

Finally, the Principle of Least Privilege (PoLP) ensures that users are granted only the minimum access necessary to perform their job functions. For example, an intern should have limited access to project folders but no access to financial records. By implementing these best practices, organizations can enhance security and prevent unauthorized access to sensitive systems and data.